Security Findings

TRACEGUARD | Evidence snapshot

Schema Version
1.0

Bundle Id
aa4c5775-1f64-4555-9f96-6dc16bdca6cb

Generated At
2026-10-31T22:05:12.212Z

Scan

Id
6379a4ea-70e3-4aaa-915c-f885e4a69512

Source
OFFLINE DEMO ? simulated external evidence ? ZIP upload

Created At
2026-10-31T22:05:12.082Z

Inventory Sha256
0ef4924823d675252f29e8df666bddd676ceba93e9e522fcbe503d2983ff21e8

Coverage

Status
complete

Checked At
2026-10-31T22:05:12.212Z

Package Instances
1

Matched
1

No Known Match
0

Unknown
0

Findings Included
1

Findings Omitted
0

Limitations

1.
This report is a point-in-time snapshot of the saved inventory and fresh OSV queries, not a live deployment assessment.

2.
Dependency presence and advisory version matches do not prove runtime execution, attacker control, or actual exploitability.

3.
No known advisory match is not a safety guarantee. Unknown, failed, paginated, or skipped checks are not clean findings.

4.
Advisory IDs can be aliases of the same underlying issue; counts describe package instances, not distinct exploitable vulnerabilities.

5.
Details are fetched for at most 40 unique advisory IDs; at most 100 matched package instances and 20 advisory IDs per finding are included. Descriptions, references, paths and source evidence are bounded.

6.

Source-provided CVSS vectors are retained without inventing numeric scores or priorities. Withdrawn or mismatched records require manual review.

7.
A verified candidate is an advisory-listed fixed release that exists in its ecosystem registry and returns no known OSV match at verification time. It is not a guarantee of safety, compatibility, or that every relevant fix was published.

8.
At most three candidate releases per package/version are checked, for at most 20 unique pairs. If no candidate is verified, manual review is required. Major-version changes may require migration.

9.
Transitive updates require changes to the owning parent or carefully reviewed root overrides. No dependency graph or lockfile is changed automatically.

10.
Only server-recorded scoped reachability results from this server process are included (latest result per instance, at most 100 instances per scan and 100 recent scans; not restored after restart). Their affected-export mappings are user-declared; NOT REACHABLE applies only within each declared coverage and is never a global safety claim.

11.
No source code, submitted package scripts, or package installation is executed while preparing these reports. Testing and release-note review remain the maintainer's responsibility.

Report Type
security-findings

Title
Security Findings

Findings

1.

Id
F-001

Package

Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Name
lodash

Version
4.17.20

Install Path
node_modules/lodash

Project
package-lock.json

Is Project
false

Direct
true

Transitive
false

Resolved
https://registry.npmjs.org/lodash/-/lodash-4.17.20.tgz

What Is Wrong
OSV returned 1 advisory ID(s) for lodash@4.17.20 at this installed location.

Why It Matters
The locked dependency includes a version associated with published security advisories. Dependent packages or project roots may inherit this dependency impact. The advisory preconditions and application exposure must be evaluated separately.

Advisories

1.

Id
GHSA-DEMO-0001

Source
https://api.osv.dev/v1/vulns/GHSA-DEMO-0001

Verification
verified

Summary
SIMULATED advisory for the offline judge demo

Description
Synthetic fixture evidence, not a real vulnerability assessment.

Aliases
(none recorded)

Severity
(none recorded)

Fixed Versions

1.
4.17.21

References

1.
https://osv.dev/vulnerability/GHSA-DEMO-0001

Affected Versions

1.
SEMVER: [{"introduced":"0"},{"fixed":"4.17.21"}]

Dependency Impact

Parent Count
1

Parents

1.

Id
urn:traceguard:component:f7dd3cc7a677a4603874ca2973e47a431ce3bd99 8c3e7e92237762327e666b24

Name
traceguard-judge-fixture

Version
1.0.0

Install Path

Root Paths

1.

1.
urn:traceguard:component:f7dd3cc7a677a4603874ca2973e47a431ce3bd99 8c3e7e92237762327e666b24

2.
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Truncated
false

Reachability

Status
REACHABLE

Report

Status
REACHABLE

Reason
A syntactic call path reaches the user-declared affected export of the selected locked package instance.

Target

Package Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Export Name
default

Mapping
user-declared export; not independently verified

Coverage

Entrypoints

1.

File
src/entry.js

Symbol
handler

Analyzed Files

1.
src/entry.js

Source Files Available
1

Skipped Sources
(none recorded)

Functions Visited
1

Calls Examined
1

Complete For Declared Entrypoints
true

Boundary
Captured application source ? declared export of the selected locked npm package instance.

Evidence

1.

File
src/entry.js

Line
2

Column
1

Snippet
export function handler() {

Kind
entry

From
<declared entrypoint>

To
src/entry.js#handler

2.

File
src/entry.js

Line
3

Column
10

Snippet

return lodash({});

Kind
target

From
src/entry.js#handler

To
lodash@4.17.20:default

Gaps
(none recorded)

Limitations

1.
Syntactic, context-insensitive ESM traversal of captured JS/JSX/TS/TSX/MJS/CJS source; no code is executed.

2.
Entrypoints are user-declared. Module initialization and an optional named/default exported function are roots. Other externally invoked exports are outside coverage.

3.
Target mapping is user-declared and not verified against an advisory. A target denotes an exported API boundary, not an internal library function.

4.
External package initialization and internal code, node_modules, generated/missing source, native code, framework dispatch, callbacks, dynamic imports, CommonJS, reflection, and computed calls are not modeled.

5.
Branches are conservatively traversed without feasibility analysis. REACHABLE means a syntactic call path, not proven runtime execution or exploitability.

6.
NOT REACHABLE applies only to declared entrypoints, captured source, and the exported-boundary model. It is not evidence of application safety.

7.
Source capture: 200 files, 256 KiB/file, 2 MiB total. Traversal: 1,000 units, 5,000 calls, 100,000 AST visits; evidence limited to 100 records.

Exploitability
NOT ASSESSED

Inventory Warnings
(none recorded)

Package Risk

Checked At
2026-10-31T22:05:12.212Z

Coverage

Total
1

Metadata Checked
1

Unavailable
0

Skipped
0

Results

1.

Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Name
lodash

Version
4.17.20

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures
(none recorded)

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/lodash/4.17.20

Metadata

Description
SIMULATED registry metadata for offline demonstration

License

Maintainers
(none recorded)

Lifecycle Scripts

Limitations

1.
Heuristics are review signals, not proof of malicious intent. NO SIGNALS is not a safety guarantee. Metadata can be publisher-controlled.

2.
Name similarity uses a fixed reference list v1 (react, react-dom, express, lodash, axios, typescript, webpack, vite, eslint, prettier, chalk, commander, mongoose, next, jquery, dotenv), one edit or adjacent transposition, minimum length five; scoped names are excluded. It does not cover all typosquatting or dependency confusion.

3.
At most 100 unique exact package/version pairs and 1,000 instances are included, with a 15-second metadata deadline and 1 MiB response limit. Unavailable or omitted data is not clean.

4.
Integrity compares recorded lock and registry digest strings only. Tarballs, installed bytes, signatures and provenance attestations are not downloaded or cryptographically verified. Matching metadata does not establish safety.

5.
Provenance is registry-advertised evidence only. Missing provenance or signatures does not imply malware. Lifecycle scripts are common in legitimate packages and are never executed.

6.
CONFIRMED MALICIOUS requires a fresh OSV version match and a verified, non-withdrawn MAL- advisory for the same

npm package. This is an attributed source verdict, not an independent analysis; other advisory IDs and heuristics cannot confirm malware. Advisory detail coverage limits also apply.

Sources

1.
https://github.com/npm/registry/blob/main/docs/responses/package- metadata.md

2.
https://docs.npmjs.com/viewing-package-provenance/

3.
https://docs.npmjs.com/cli/v11/commands/npm-audit/

4.
https://osv.dev/